

Apna College Website Broken Access Control — Paid Course HLS Video Content Accessible Without Enrollment

Summary

A Broken Access Control issue allows paid course video content to be accessed outside the intended Apna College course authorization flow.

While accessing a video from a paid/restricted course, the application exposes a Wistia HLS `.m3u8` playlist through the client. The HLS request to `fast.wistia.com` does not contain an Apna College authentication cookie or authorization token.

The playlist response is returned with `HTTP/2 200 OK` and contains direct `embed-cloudfront.wistia.com` URLs for the video's different resolutions.

The resulting media URL can then be accessed from an unauthenticated Incognito session and the video plays successfully, without requiring the Apna College account to be logged in or enrolled in the course.

This effectively separates access to the paid video content from the application's intended authentication/enrollment boundary.

Vulnerability Type

Broken Access Control / Missing Authorization

Relevant category:

- OWASP Top 10 — **A01: Broken Access Control**
 - CWE-862 — **Missing Authorization**
-

Severity

High

Reasoning

The issue potentially allows unauthorized users to access paid course video content without satisfying the application's intended course enrollment/access requirements.

The impact is primarily **confidentiality / unauthorized access to paid content**.

Final severity should ultimately be determined according to the program's own vulnerability classification and scope.

Affected Component

Apna College course video player

The vulnerable media flow involves:

```
www.apnacollege.in
    ↓
Wistia player
    ↓
fast.wistia.com
    ↓
embed-cloudfront.wistia.com
    ↓
HLS video segments
```

Steps to Reproduce

1. Log in normally

Log into an account that has legitimate access to the relevant course/video.

Navigate to the relevant paid/restricted course and open the video.

2. Inspect the video network requests

Open the browser's Developer Tools:

```
F12 → Network
```

Filter requests using:

```
m3u8
```

The video player generates an HLS playlist request similar to:

```
GET /embed/medias/6mcugh2no5.m3u8 HTTP/2
Host: fast.wistia.com
Origin: https://www.apnacollege.in
Referer: https://www.apnacollege.in/
```

Important observation

The request does **not** contain:

```
Cookie: ...
```

or:

```
Authorization: ...
```

There is therefore no Apna College session credential visible in the media request shown above.

3. Observe the server response

The request receives:

```
HTTP/2 200 OK
Content-Type: application/x-mpegURL
```

Relevant response headers include:

```
Access-Control-Allow-Origin: *
Cache-Control: public, no-cache
```

The response contains an HLS master playlist:

```
#EXTM3U
#EXT-X-VERSION:3
```

with multiple video resolutions.

For example:

```
#EXT-X-STREAM-INF:AVERAGE_BANDWIDTH=937707,
BANDWIDTH=2161576,
RESOLUTION=1920x1080,
```

```
NAME="1080p"
```

```
https://embed-cloudfront.wistia.com/deliveries/[REDACTED].m3u8
```

The playlist similarly exposes 224p, 360p, 540p and 720p variants.

4. Follow the HLS media URL

The master playlist exposes a direct Wistia CloudFront media playlist:

```
https://embed-cloudfront.wistia.com/deliveries/[REDACTED].m3u8
```

The browser subsequently requests the associated `.ts` video segments, which were observed returning:

```
HTTP 200
```

in Burp HTTP history.

5. Test the media URL without the authenticated session

Copy the relevant media playlist URL and open it in a fresh Incognito/private browsing session where the Apna College account is **not logged in**.

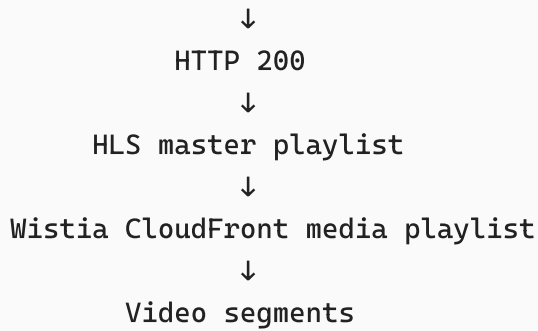
The video content remains accessible and plays successfully.

This demonstrates that access to the underlying media does not depend on the Apna College authenticated session.

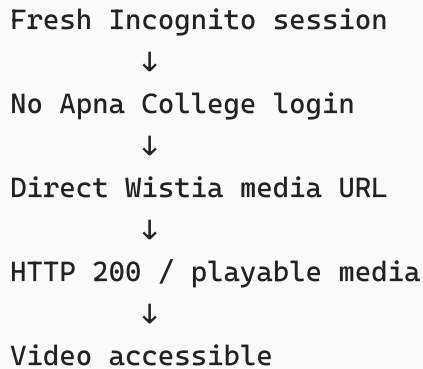
Proof of Concept

Authenticated course flow

```
Apna College paid/restricted course
    ↓
Course player
    ↓
Wistia HLS request
    ↓
GET /embed/medias/6mcugh2no5.m3u8
```



Unauthenticated flow



Therefore, the application's course authorization boundary is not being enforced at the underlying media resource.

Expected Behavior

The HLS media associated with a paid/restricted course should only be accessible to users who satisfy the appropriate authorization requirements, such as:

- authenticated user;
- valid course enrollment;
- valid subscription/purchase;
- valid temporary media authorization/token.

A direct media request from an unauthorized or non-enrolled user should be rejected.

For example:

401 Unauthorized

or:

403 Forbidden

or the application should provide a properly authorized, short-lived media URL.

Actual Behavior

The application exposes a Wistia HLS playlist that:

1. Can be retrieved without an Apna College Cookie or Authorization header.
 2. Returns HTTP 200 OK .
 3. Contains direct Wistia CloudFront media playlist URLs.
 4. Leads to video segments returning HTTP 200 .
 5. Can be accessed from an unauthenticated Incognito session.
 6. Allows the associated video to play outside the normal authenticated course flow.
-

Security Impact

An unauthorized user may be able to access paid/restricted course video content without satisfying the intended enrollment or subscription requirements.

Potential impact includes:

- Unauthorized access to paid educational content.
- Circumvention of the application's course-level access control.
- Loss of exclusivity of paid course material.
- Potential redistribution of course videos.
- Financial/revenue impact if paid content can be consumed without purchasing/enrolling.

The issue appears to occur because authorization is enforced at the application/course-player layer but is not enforced on the underlying media resource exposed to the client.

Technical Details

The vulnerable HLS request observed was:

```
GET /embed/medias/6mcugh2no5.m3u8 HTTP/2
Host: fast.wistia.com
Origin: https://www.apnacollege.in
Referer: https://www.apnacollege.in/
```

No application authentication material was present in the request:

```
Cookie: [NOT PRESENT]
Authorization: [NOT PRESENT]
```

The response:

```
HTTP/2 200 OK
Content-Type: application/x-mpegURL
Access-Control-Allow-Origin: *
Cache-Control: public, no-cache
```

returned an HLS master playlist containing multiple direct media playlists.

Example, with the identifier redacted:

```
https://embed-cloudfront.wistia.com/deliveries/[REDACTED].m3u8
```

The corresponding video segments were observed in Burp HTTP history with successful 200 responses.

Why This Is an Access-Control Issue

The important issue is **not simply that Wistia uses publicly accessible URLs**.

The security boundary is:

```
Paid Course
  ↓
Apna College authorization
  ↓
Video
```

The application exposes the underlying media URL to the client, and that media URL remains usable without the application's authentication/enrollment context.

Thus:

```
Application authorization
  ≠
Media authorization
```

The media layer should enforce an authorization mechanism consistent with the application's course-access requirements.

Evidence

Evidence 1 — HLS request

```
GET /embed/medias/6mcugh2no5.m3u8 HTTP/2
Host: fast.wistia.com
Origin: https://www.apnacollege.in
Referer: https://www.apnacollege.in/
```

No Cookie or Authorization header was present.

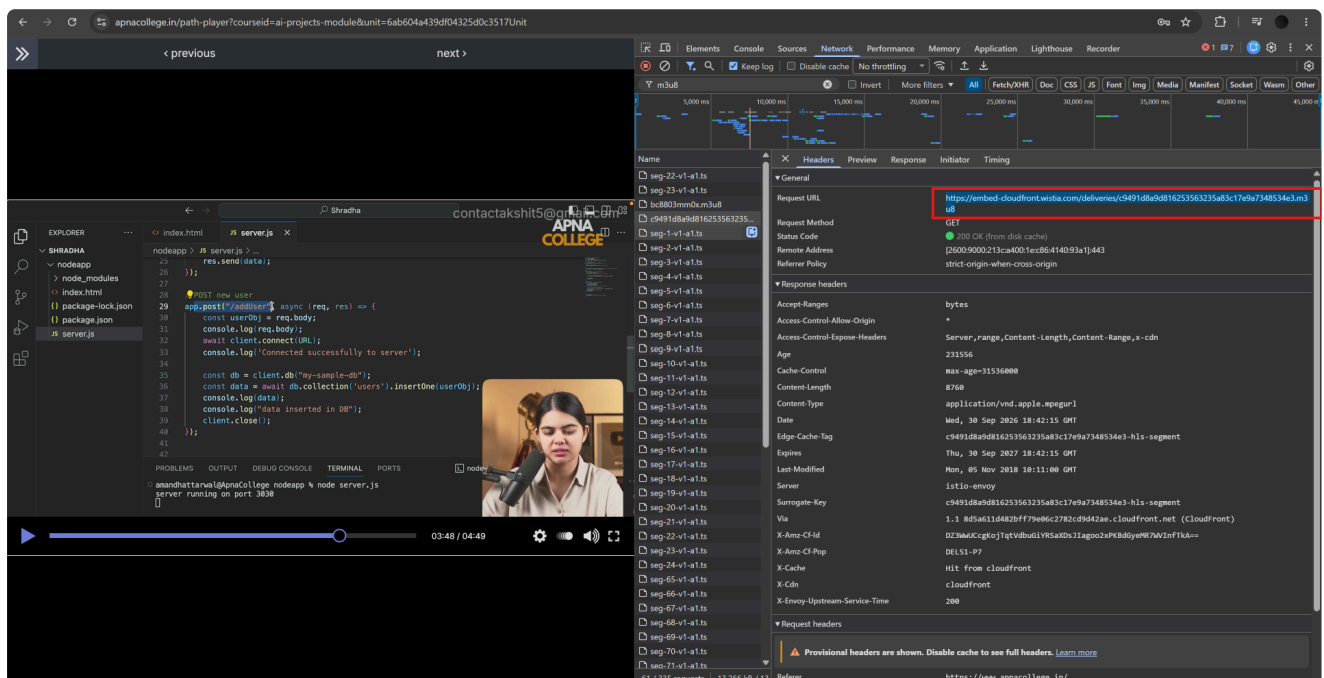
Evidence 2 — Successful response

```
HTTP/2 200 OK
Content-Type: application/x-mpegURL
```

Evidence 3 — HLS playlist

The response contains multiple resolution-specific media URLs:

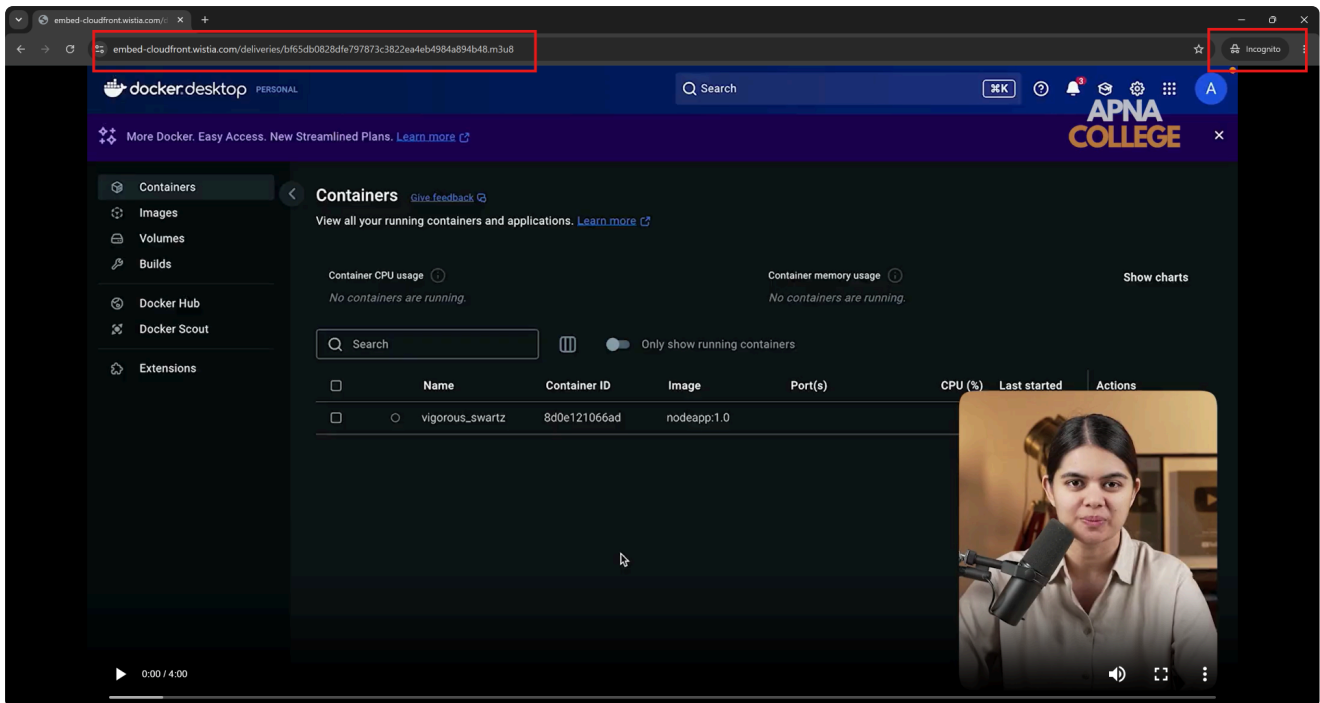
```
1080p → https://embed-cloudfront.wistia.com/deliveries/[REDACTED].m3u8
720p  → https://embed-cloudfront.wistia.com/deliveries/[REDACTED].m3u8
540p  → https://embed-cloudfront.wistia.com/deliveries/[REDACTED].m3u8
360p  → https://embed-cloudfront.wistia.com/deliveries/[REDACTED].m3u8
224p  → https://embed-cloudfront.wistia.com/deliveries/[REDACTED].m3u8
```



The screenshot shows a web browser with a video player and the developer console. The video player is displaying a video from APNA College. The developer console shows the network tab with a list of requests. The selected request is for the HLS playlist, which is a 300 OK response from the CloudFront delivery service. The response headers show the content type as application/vnd.apple.mpegurl and the content length as 8768 bytes. The response body is a playlist of media segments.

Evidence 4 — Unauthenticated playback

The resulting media URL was opened in a fresh Incognito session without an active Apna College login, and the video remained playable.



Burp Evidence

The same behavior was also observed through Burp Suite.

Burp HTTP history showed:

```
fast.wistia.com
GET /embed/medias/6mcugh2no5.m3u8
200
m3u8
```

The screenshot shows the Burp Suite interface with the HTTP History tab selected. A list of requests is displayed, with request 1566 highlighted in red. The request details for 1566 are shown in the Request tab, indicating a GET request to a Wistia CDN URL. The response tab shows the raw response data, including headers and body content.

followed by requests to:

`embed-cloudfront.wistia.com`

for the video segments, which returned:

200

This confirms that the browser was retrieving the HLS media directly from the Wistia/CDN infrastructure.

Recommended Remediation

The application should enforce authorization at the **media-delivery layer**, rather than relying solely on the course/player page to enforce access.

Possible approaches include:

1. Short-lived signed media URLs

Generate per-user/per-session signed URLs with:

- short expiration;
- course/video binding;
- appropriate authorization checks.

2. Validate enrollment before issuing media access

Before returning an HLS playlist or media URL, verify:

```
Authenticated user
      +
Valid enrollment/subscription
      +
Permission for requested video
```

3. Protect the HLS playlist itself

The `.m3u8` endpoint should not provide unrestricted access to paid content.

4. Protect downstream media resources

Authorization should also apply to the actual CloudFront media playlists/segments, not only the initial course page.

5. Avoid exposing reusable permanent media URLs

If direct media URLs are required, use appropriately scoped and time-limited authorization.

Suggested Title

Broken Access Control: Paid Course HLS Video Content Accessible Without Enrollment

Alternative shorter title:

Paid Course Videos Accessible Without Authentication via Exposed Wistia HLS URLs

Short Executive Summary

A paid/restricted course video can be accessed outside the intended Apna College authorization flow. The course player exposes a Wistia HLS `.m3u8` playlist that can be retrieved without an Apna College authentication cookie or authorization header. The playlist exposes direct Wistia CloudFront media URLs, and the resulting video remains playable from an unauthenticated Incognito session. This allows the underlying paid course video to be accessed independently of the application's course enrollment controls.